

Complete Nmap Guide

Scan Techniques & Firewall Evasion 

SECTION 1: Introduction to Nmap

What is Nmap? Nmap (Network Mapper) is a free and open-source utility for network discovery and security auditing. It uses raw IP packets to determine what hosts are available, what services they offer, and what operating systems they are running.

Where it is used:

- **Penetration Testing:** Identifying open ports and vulnerabilities on target systems.
- **Network Auditing:** Creating an inventory of devices on a corporate network.
- **System Administration:** Monitoring host uptime and service availability.

SECTION 2: Scan Techniques

Understanding these scans allows you to choose the right approach based on your need for speed, stealth, or bypassing security controls.

1. TCP SYN Scan (-sS)

Definition: Also called a "half-open" scan. Sends a SYN packet and waits for a SYN/ACK. If received, it sends an RST to tear down the connection before it logs.

Flag: -sS

When to use: Default scan. Use for fast, reliable, and stealthy scanning.

Where to use: General network recon where stealth is preferred over a full connection.

Syntax: nmap -sS <target>

Example: nmap -sS 192.168.1.1

2. TCP Connect Scan (-sT)

Definition: Completes the full 3-way TCP handshake (SYN, SYN/ACK, ACK). Highly visible.

Flag: -sT

When to use: When you do not have root/admin privileges, or when scanning IPv6 networks.

Where to use: Internal auditing where stealth doesn't matter (connections will be logged by the target).

Syntax: nmap -sT <target>

Example: nmap -sT 10.0.0.5

3. ACK Scan (-sA)

Definition: Sends an ACK packet to see if a port is filtered (blocked by a firewall) or unfiltered. Doesn't determine if open/closed.

Flag: -sA

When to use: To map out firewall rule sets and determine if a firewall is stateful.

Where to use: Penetration testing against perimeter firewalls.

Syntax: nmap -sA <target>

Example: nmap -sA 192.168.0.100

4. Window Scan (-sW)

Definition: Similar to ACK scan, but exploits a quirk in some OSs' TCP window sizes to distinguish between open and closed ports.

Flag: -sW

When to use: When scanning older systems that exhibit this specific TCP window anomaly.

Where to use: Legacy network environments.

Syntax: nmap -sW <target>

Example: nmap -sW 10.10.10.10

5. Maimon Scan (-sM)

Definition: Sends a FIN/ACK packet. Named after Uriel Maimon. Open ports ignore it, closed ports reply with RST (on older BSD systems).

Flag: -sM

When to use: Bypassing stateless firewalls on specific older Unix variants.

Where to use: Auditing legacy BSD-derived systems.

Syntax: nmap -sM <target>

Example: nmap -sM 192.168.1.50

6. UDP Scan (-sU)

Definition: Sends empty UDP headers to target ports. Relies on ICMP port unreachable errors to determine if ports are closed.

Flag: -sU

When to use: To discover UDP services like DNS, SNMP, and DHCP.

Where to use: Comprehensive security audits (often combined with TCP scans).

Syntax: nmap -sU <target>

Example: nmap -sU -p 53,161 10.0.0.1

7. NULL Scan (-sN)

Definition: Sends a packet with zero TCP flags set. Open ports ignore; closed ports send RST.

Flag: -sN

When to use: Evading stateless firewalls and IDS/IPS that look for SYN packets.

Where to use: Linux/Unix targets (Does not work on Windows).

Syntax: nmap -sN <target>

Example: nmap -sN 192.168.2.1

8. FIN Scan (-sF)

Definition: Sends a packet with only the FIN flag set.

Flag: -sF

When to use: Similar to NULL scan, used to sneak past basic firewalls.

Where to use: Stealth operations against non-Windows systems.

Syntax: nmap -sF <target>

Example: nmap -sF 10.10.10.5

9. Xmas Scan (-sX)

Definition: Sets FIN, PSH, and URG flags, lighting up the packet "like a Christmas tree."

Flag: -sX

When to use: Stealth scanning and bypassing non-stateful firewalls.

Where to use: Unix/Linux environments. (Fails against Windows).

Syntax: nmap -sX <target>

Example: nmap -sX 192.168.1.200

10. Custom Scan (--scanflags)

Definition: Allows you to specify your own custom combination of TCP flags.

Flag: --scanflags

When to use: When you know the exact rules of an IDS/firewall and need a hyper-specific packet to bypass it.

Where to use: Advanced red-teaming scenarios.

Syntax: nmap --scanflags <FLAGS> <target>

Example: nmap --scanflags URGACKPSH 10.0.0.1

11. Idle Scan (-sI)

Definition: A completely blind, stealthy scan that bounces packets off a "zombie" host, hiding your IP completely.

Flag: -sI

When to use: When ultimate stealth is required and you need to frame another IP for the scan.

Where to use: High-security environments where your IP being logged is unacceptable.

Syntax: nmap -sI <zombie_host> <target>

Example: nmap -sI zombie.lan 192.168.1.100

12. SCTP INIT Scan (-sY)

Definition: The SCTP equivalent of a TCP SYN scan (half-open).

Flag: -sY

When to use: When assessing SCTP services (often used in telecom).

Where to use: 4G/5G mobile networks, telecom infrastructure.

Syntax: nmap -sY <target>

Example: nmap -sY 10.10.20.50

13. SCTP COOKIE-ECHO (-sZ)

Definition: Advanced stealth scan for SCTP that drops a COOKIE-ECHO packet to bypass stateless firewalls.

Flag: -sZ

When to use: Evading basic SCTP firewalls.

Where to use: Telecom auditing.

Syntax: nmap -sZ <target>

Example: nmap -sZ 10.10.20.50

14. IP Protocol Scan (-sO)

Definition: Scans for supported IP protocols (TCP, UDP, ICMP, etc.) rather than ports.

Flag: -sO

When to use: Early recon to understand the target's network stack capabilities.

Where to use: Broad network discovery phases.

Syntax: nmap -sO <target>

Example: nmap -sO 192.168.1.1

15. FTP Bounce Scan (-b)

Definition: Exploits a vulnerable FTP server to proxy your scan through it.

Flag: -b

When to use: Very rarely today, as most modern FTP servers have disabled this feature.

Where to use: Legacy systems or CTF (Capture The Flag) challenges.

Syntax: nmap -b <user:pass@ftp_server> <target>

Example: nmap -b anon:-@ftp.site.com 10.0.0.1



SECTION 3: Firewall & IDS Evasion Techniques

Security devices block standard scans. These flags manipulate packets to slip past defenses.

1. Packet Fragmentation (-f, --mtu)

Definition: Splits IP packets into tiny fragments.

Purpose: Makes it harder for Intrusion Detection Systems (IDS) to reassemble and detect the scan signature.

When to use: Bypassing signature-based IDS.

Syntax: nmap -f <target>

Example: nmap -f 192.168.1.1

2. Decoys (-D)

Definition: Spoofs other IP addresses alongside yours, making it look like the target is being scanned by multiple hosts.

Purpose: Obscure your actual IP in a flood of fake logs.

When to use: When you want to confuse the defense team analyzing the firewall logs.

Syntax: `nmap -D <decoy1,decoy2,ME> <target>`

Example: `nmap -D 10.0.0.1,10.0.0.2,ME 192.168.1.1`

3. Source IP Spoofing (-S)

Definition: Fakes your source IP address entirely.

Purpose: To make the scan look like it's coming from a trusted internal IP. (Note: you will not see the replies unless you can sniff the traffic).

When to use: When you know a specific IP is whitelisted by the firewall.

Syntax: `nmap -S <Spoofed_IP> <target>`

Example: `nmap -S 192.168.1.254 10.0.0.5`

4. Interface Selection (-e)

Definition: Forces Nmap to use a specific network interface.

Purpose: Overrides default routing to send packets through a specific adapter (e.g., VPN tunnel, eth1).

When to use: In complex multi-homed environments.

Syntax: `nmap -e <interface> <target>`

Example: `nmap -e tun0 192.168.1.1`

5. Source Port Manipulation (-g / --source-port)

Definition: Sets a specific source port for the outgoing scan packets.

Purpose: Firewalls often carelessly whitelist traffic originating from ports like 53 (DNS) or 80 (HTTP).

When to use: To exploit misconfigured firewall trust rules.

Syntax: `nmap -g <port> <target>`

Example: `nmap -g 53 10.0.0.1`

6. Proxies (--proxies)

Definition: Relays connections through HTTP or SOCKS4 proxies.

Purpose: Hides your true origin IP and bypasses geographic or IP blocks.

When to use: Red-teaming campaigns requiring extreme anonymity.

Syntax: `nmap --proxies <url1,url2> <target>`

Example: `nmap --proxies socks4://127.0.0.1:9050 10.0.0.1`

7. Data Injection (--data, --data-string, --data-length)

Definition: Appends custom payloads, ASCII strings, or random bytes to scan packets.

Purpose: Some firewalls drop completely empty TCP/UDP packets. Adding data makes packets look legitimate.

When to use: Evading simple packet-size filters.

Syntax: `nmap --data-length <num> <target>`

Example: `nmap --data-length 25 192.168.1.1`

8. IP Options (--ip-options)

Definition: Sends packets with specified IP routing options.

Purpose: Exploits source routing to control the path packets take through a network.

When to use: Bypassing strict routing controls.

Syntax: `nmap --ip-options <options> <target>`

Example: `nmap --ip-options "R" 10.0.0.1`

9. TTL Manipulation (--ttl)

Definition: Sets a custom IPv4 Time-To-Live field.

Purpose: Can be used to bypass poorly configured IDS systems by ensuring the packet expires right after the IDS but before the target (or vice versa).

When to use: Advanced IDS evasion.

Syntax: `nmap --ttl <value> <target>`

Example: `nmap --ttl 64 192.168.1.1`

10. MAC Spoofing (--spoof-mac)

Definition: Forges the MAC address of your network interface.

Purpose: Bypasses MAC filtering mechanisms on local networks (e.g., port security or captive portals).

When to use: When attacking targets on the same local subnet.

Syntax: `nmap --spoof-mac <mac|vendor> <target>`

Example: `nmap --spoof-mac Apple 192.168.1.1`

11. Bad Checksum (--badsum)

Definition: Sends packets with an intentionally invalid TCP/UDP/SCTP checksum.

Purpose: Used to discover if a firewall/IDS is inspecting traffic. A proper host will drop a bad checksum, but some IDS devices will respond to it.

When to use: Mapping the location of IDS sensors on the network.

Syntax: `nmap --badsum <target>`

Example: `nmap --badsum 10.0.0.1`

SECTION 4: Tips & Best Practices

 **Legal Warning:** Never scan networks or devices you do not own or have explicit, written permission to test. Unauthorized port scanning can be considered a hostile act or illegal under computer crime laws.

Safe Usage Checklist

- Always define scopes clearly before a penetration test.
- Use -T timing templates (e.g., -T2) to slow down scans to avoid knocking over fragile IoT devices or legacy servers.
- Verify your target IP addresses multiple times before hitting "Enter".

Common Mistakes

- Scanning the entire 65,535 port range over a slow connection without tuning timing parameters.
- Running aggressive scans (-A) against unstable production databases.
- Forgetting that UDP scans (-sU) are extremely slow and often require specific port targeting to finish in a reasonable time.

⚡ SECTION 5: Quick Cheat Sheet

Icon	Task / Flag	Description	Quick Command
😬	TCP SYN (Stealth) -sS	Default, stealthy half-open scan.	<code>nmap -sS target</code>
👤	TCP Connect -sT	Full connection, noisy, no root needed.	<code>nmap -sT target</code>
📡	UDP Scan -sU	Checks for open UDP ports.	<code>nmap -sU target</code>
🧩	Fragment -f	Splits packets to hide from IDS.	<code>nmap -f target</code>
🕸	Decoy -D	Hides your IP among fake scan IPs.	<code>nmap -D RND:10 target</code>
📠	Source Port -g	Exploits firewalls trusting port 53/80.	<code>nmap -g 53 target</code>
👤	MAC Spoof --spoof-mac	Changes physical address for local scans.	<code>nmap --spoof-mac 0 target</code>